

Room - OWASP Top 10 2025: IAAA Failures

This room breaks down 3 of the OWASP Top 10 2025 categories. In this room, you will learn about the categories that are related to failures in how Identity, Authentication, Authorisation, and Accountability (IAAA) is implemented in the application. You will put the theory into practice by completing supporting challenges. The following categories are covered in this room:

1. A01: Broken Access Control
2. A07: Authentication Failures
3. A09: Logging & Alerting Failures

IAAA is a simple way to think about how users and their actions are verified on applications. Each item plays a crucial role and it isn't possible to skip a level. That means, if a previous item isn't being performed, you cannot perform the later times. The four items are:

- **Identity** - the unique account (e.g., user ID/email) that represents a person or service.
- **Authentication** - proving that identity (passwords, OTP, passkeys).
- **Authorisation** - what that identity is allowed to do.
- **Accountability** - recording and alerting on who did what, when, and from where.

Broken Access Control occurs when a web application fails to properly check whether a user is allowed to access a resource or perform an action.

A very common example is **IDOR (Insecure Direct Object Reference)**.

Example:

/account?id=7

If changing it to:

/account?id=6

lets you view another user's account, the application has broken access control because it trusts the client input without verifying permissions.

Two major types:

- **Horizontal Privilege Escalation**

- Accessing another user's data while having the same role.
- Example: User A viewing User B's bank account.
- **Vertical Privilege Escalation**
 - Gaining higher privileges than intended.
 - Example: Normal user accessing admin-only pages.

Core lesson:

- Applications must validate authorization on the **server side for every request**.
- Simply hiding IDs or trusting user-supplied values is insecure.

Authentication Failures occur when a web application cannot properly verify a user's identity or securely manage sessions. These weaknesses can allow attackers to impersonate users or gain unauthorized access.

Common causes include:

- **Username Enumeration**
 - The application reveals whether a username exists.
 - Example: "User not found" vs "Wrong password".
- **Weak Password Security**
 - Easy-to-guess passwords.
 - No rate limiting or account lockout, enabling brute-force attacks.
- **Logic Flaws**
 - Mistakes in login or registration workflows.
 - Example: treating `admin` and `aDmiN` as the same account inconsistently.
- **Insecure Session/Cookie Handling**
 - Poorly protected session IDs or authentication cookies.
 - Can lead to session hijacking or account takeover.

When applications don't record or alert on security-relevant events, defenders can't detect or investigate attacks. Good logging underpins **accountability** (being able to prove who did what, when, and from where). In practice, failures look like missing authentication events, vague error logs, no alerting on brute-force or privilege changes, short retention, or logs stored where attackers can tamper with them.